

Yesterday, I learned how an enterprise enforces security at scale. Next, “How does a user ACTUALLY get into the network?” So today = AUTHENTICATION.

Lets understand: What actually happens when an employee sits down, enters their password, and logs into a company computer?

Authentication vs Authorization

Authentication is the process of verifying who a user is. Answers: “Are you really who you claim to be?” Examples: logging in with a username and password, using a fingerprint or Face ID, entering a one-time code, signing in with Google or GitHub. If the system confirms your identity, you are authenticated.

Authorization is the process of determining what an authenticated user is allowed to do. Answers: “What are you allowed to access or perform?” Examples: An admin can delete users, a regular user can only view their profile, some employees can access payroll data, others can’t. If the system grants or denies permissions, that is authorization.

Think: Authentication = Who are you?

Authorization = What are you allowed to do?

Kerberos Deep Dive

Kerberos is a network authentication protocol that allows users and computers to prove their identity securely without sending passwords across the network. Mainly used in AD domains. Kerberos provides Single Sign-On...Log in once -> access multiple resources without re-entering your password.

Client: The user or computer requesting access. (Ex: Kevin logs into his Windows workstation.)

Service: The resource being accessed. Ex: File server, Web server, Database

Key Distribution Center (KDC): The trusted authority that verifies identities. The Domain Controller acts as the KDC in AD. It contains the Authentication Service and Ticket Granting Service.

Step 1: User logs in. (Password used locally to prove identity to the Domain Controller.)

Step 2: Get a Ticket Granting Ticket (TGT). The Domain Controller issues a Ticket Granting Ticket. Think of it as: I have verified Kevin’s identity.

Step 3: Request Access to a Service. Kevin wants to access a file server. Instead of sending his password again, he presents the TGT.

Step 4: Receive a Service Ticket. The Domain Controller issues a service ticket for that specific server.

Step 5: Access Granted. Kevin presents the service ticket to the file server. The server trusts the ticket and grants access.

User Logs In



Domain Controller Verifies Identity



Ticket Issued



User Accesses Resources

Kerberos is more secure than repeatedly sending passwords because it reduces the exposure of the password.

Kerberoasting is an AD attack where an attacker requests Kerberos service tickets for service accounts and then attempts to crack those tickets offline to recover the service account's password.

Attack Flow:

Step 1: Attacker gets a domain account.

Step 2: Find Service Accounts. The attacker looks for accounts with Service Principal Names.

Examples: SQL services, Web services, Backup services

Step 3: Request Service Tickets. The attacker requests Kerberos tickets for those services.

Step 4: Extract the Tickets.

Step 5: Crack Offline

The Complete Domain Login Process

Step 1: User Presses Login. Enter username and password. Windows computer now needs to verify: Is Kevin really a valid domain user? The computer doesn't store all domain user accounts; that is the Domain Controller's job.

Step 2: Computer Uses DNS. Where is my Domain Controller? Ex: corp.local, and DNS returns: DC01.corp.local, 192.168.1.10. Without DNS, the workstation wouldn't know how to find the Domain Controller.

Step 3: Contact Domain Controller. "I have a user trying to log in."

Step 4: Kerberos Authentication. DC acts as Key Distribution Center. Kerberos verifies the user's identity. User receives TGT.

Step 5: Authentication complete.

Step 6: Authorization Begins. What is Kevin allowed to do? DC sends info such as: Domain Users, IT Department, VPN Users.

Step 7: Group Policy Processing. Workstation downloads Group Policy Objects.

Step 8: User Gets Desktop. Windows loads everything.

Attacker Perspective

Brute Force Attacks.

Password Spraying: Instead of many passwords against one account, the attacker tries a few common passwords against many accounts.

Credential Stuffing: Attackers use usernames and passwords leaked from another website.

Phishing.